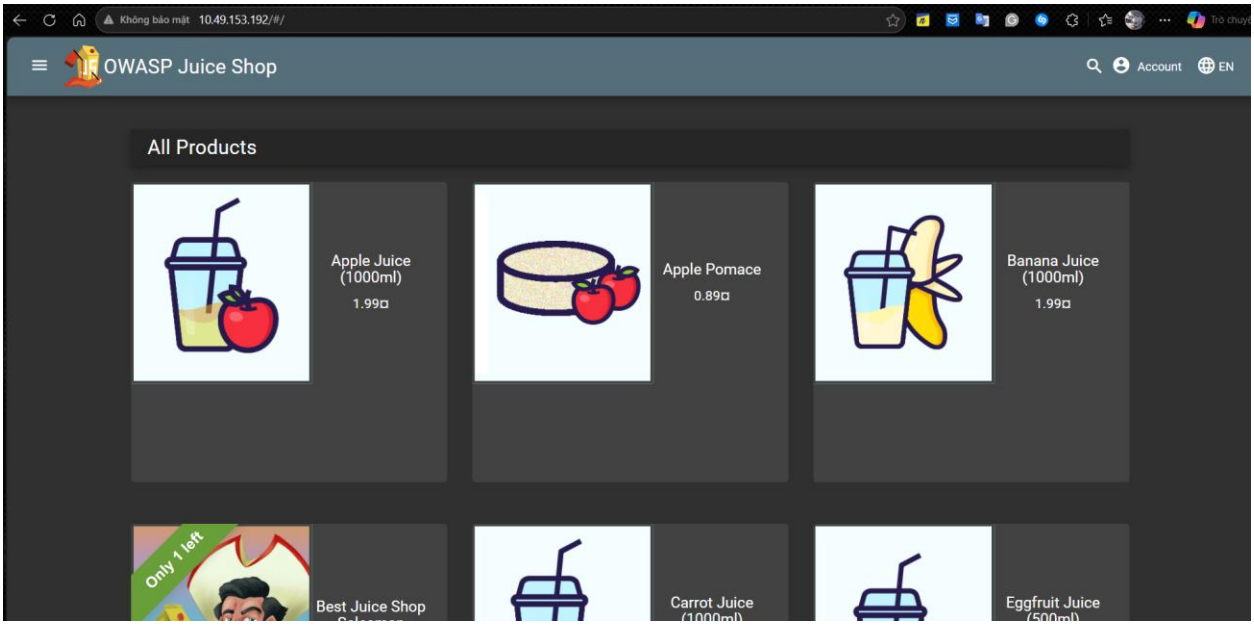
OWASP Juice Shop

Trong bài học này, chúng ta sẽ sử dụng máy chủ Attackbox của Tryhackme và trang web được dựng sẵn.



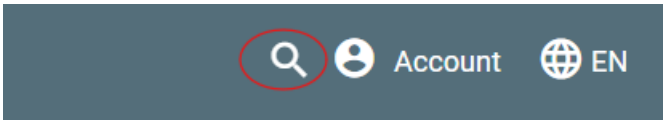
Question #1: What's the Administrator's email address?

Các đánh giá hiển thị địa chỉ email của mỗi người dùng. Khi nhấp vào sản phẩm Nước ép táo, chúng ta sẽ thấy địa chỉ email của người quản trị!

admin@juice-sh.op ✓ Correct Answer

Question #2: What parameter is used for searching?

Nhấp vào biểu tượng kính lúp ở góc trên bên phải ứng dụng sẽ hiện ra thanh tìm kiếm.



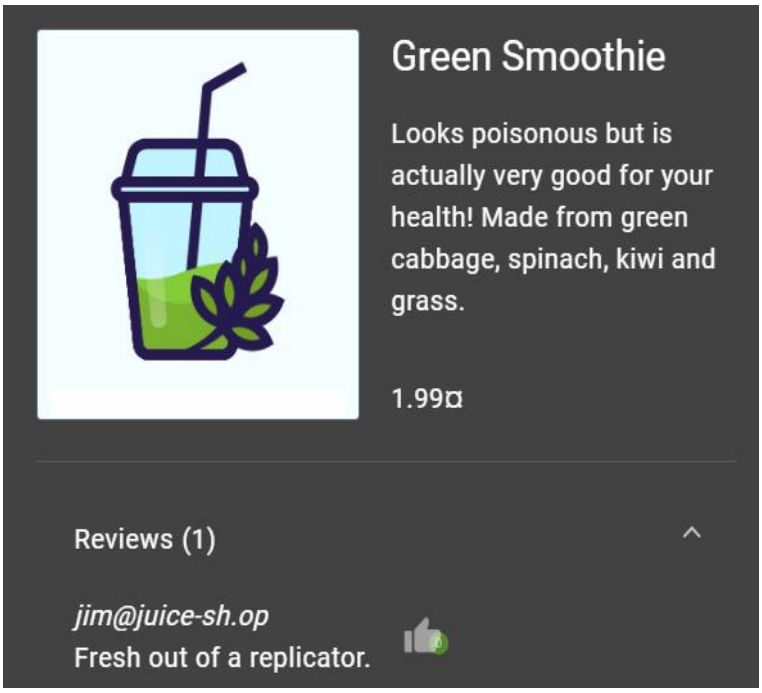
Sau đó, chúng ta nhập một đoạn văn bản bất kì và nhấn Enter, hệ thống sẽ tìm kiếm đoạn văn bản vừa nhập.

Bây giờ hãy chú ý đến URL, nó sẽ được cập nhật với đoạn văn bản chúng ta vừa nhập.

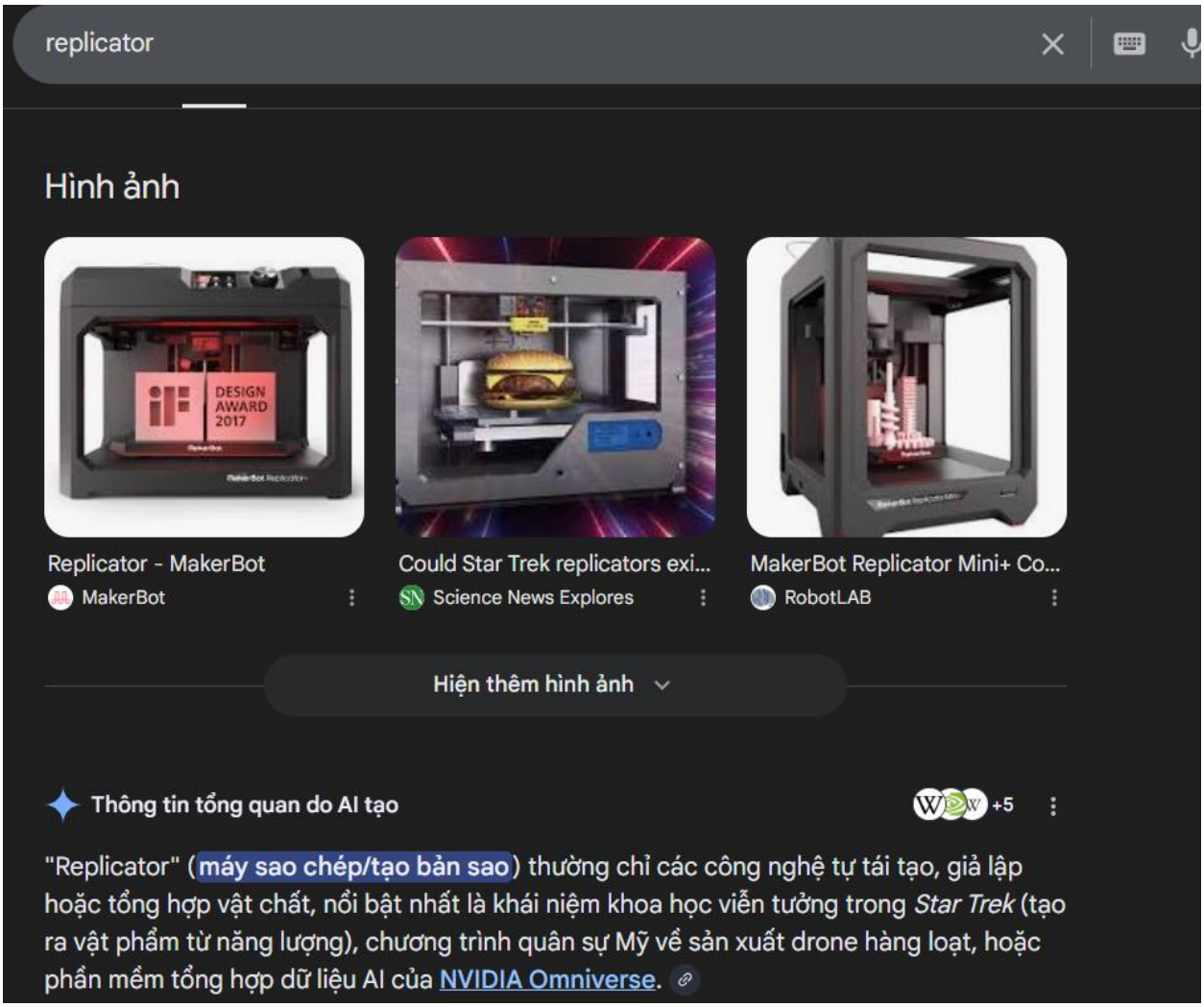
q ✓ Correct Answer

Question #3: What show does Jim reference in his review?

Jim đã viết bài đánh giá về sản phẩm Green Smoothie. Chúng ta có thể thấy anh ấy đề cập đến một thiết bị nhân bản.



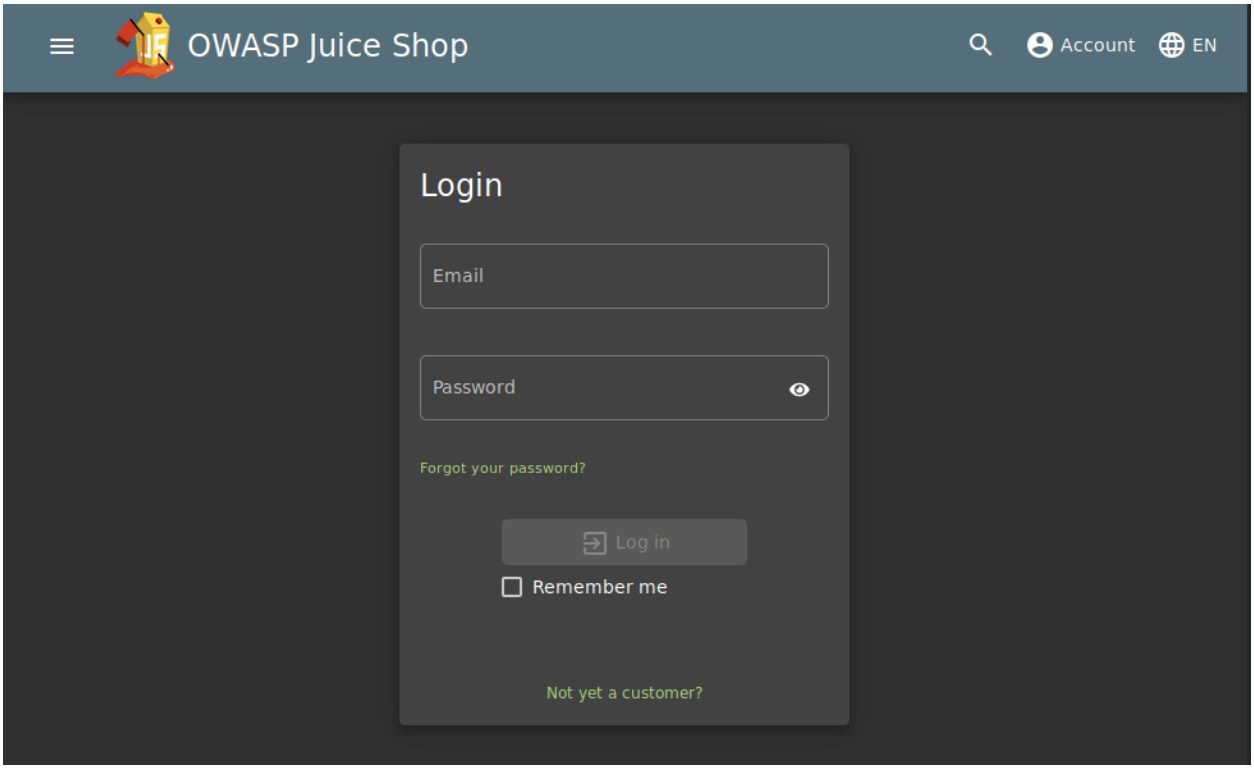
Nếu chúng ta tìm kiếm "replicator" trên Google, chúng ta sẽ nhận được kết quả cho thấy nó xuất phát từ một chương trình truyền hình có tên là Star Trek.



Star Trek

✓ Correct Answer

1. Inject the Juice

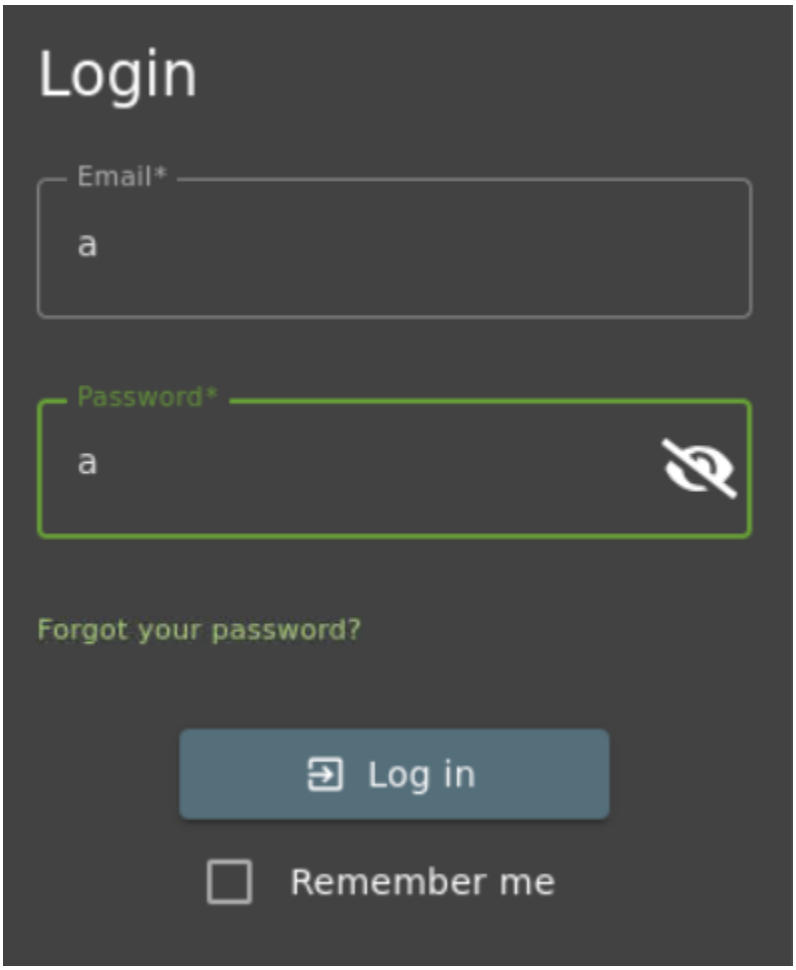


Nhiệm vụ này sẽ tập trung vào các lỗ hổng tấn công injection. Các lỗ hổng injection khá nguy hiểm đối với một công ty vì chúng có thể gây ra thời gian ngừng hoạt động và/hoặc mất dữ liệu. Việc xác định các điểm injection trong một ứng dụng web thường khá đơn giản, vì hầu hết chúng sẽ trả về lỗi. Có nhiều loại tấn công injection, một số trong đó là:

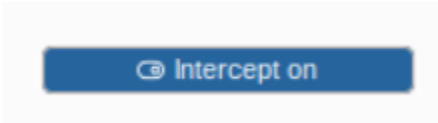
SQL Injection	Tấn công SQL Injection là khi kẻ tấn công nhập một truy vấn độc hại hoặc không đúng định dạng để truy xuất hoặc làm sai lệch dữ liệu từ cơ sở dữ liệu. Và trong một số trường hợp, đăng nhập vào tài khoản.
Command Injection	Tấn công Command Injection là khi các ứng dụng web lấy dữ liệu đầu vào hoặc dữ liệu do người dùng kiểm soát và chạy chúng như các lệnh hệ thống. Kẻ tấn công có thể làm sai lệch dữ liệu này để thực thi các lệnh hệ thống của riêng chúng. Điều này có thể thấy trong các ứng dụng thực hiện các bài kiểm tra ping được cấu hình sai.
Email Injection	Tấn công email injection là một lỗ hổng bảo mật cho phép người dùng độc hại gửi tin nhắn email mà không cần sự cho phép trước của máy chủ email. Điều này xảy ra khi kẻ tấn công thêm dữ liệu bổ sung vào các trường mà máy chủ không diễn giải chính xác.

Question #1: Log into the administrator account!

Sau khi truy cập trang đăng nhập, ta nhập thông tin bất kì vào các trường email và mật khẩu.



Trước khi nhấn nút gửi, hãy đảm bảo chế độ Chặn (Intercept mode) đã được bật.



Request

Pretty Raw Hex

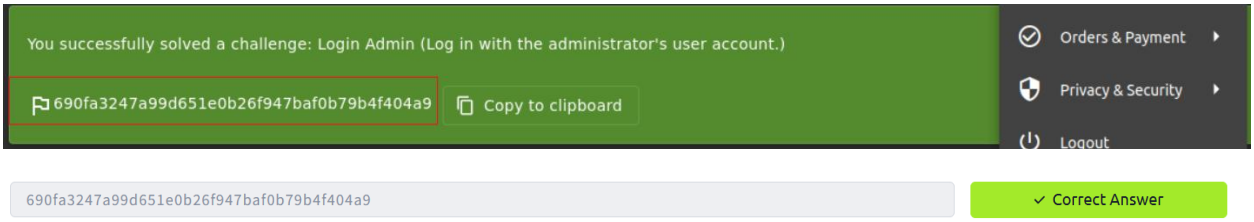
```
2  Host: 10.48.140.47
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:147.0) Gecko/20100101 Firefox/147.0
4  Accept: application/json, text/plain, */*
5  Accept-Language: en-GB,en;q=0.9
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: application/json
8  Content-Length: 28
9  Origin: http://10.48.140.47
10 Connection: keep-alive
11 Referer: http://10.48.140.47/
12 Cookie: language=en
13 Priority: u=0
14
15 {"email":"a","password":"a"}
```

Bây giờ chúng ta sẽ thay đổi chữ "a" bên cạnh email thành: **' or 1=1--** và chuyển tiếp nó đến máy chủ.

```
{"email":"' or 1=1--","password":"a"}
```

Mệnh đề 'OR' trong câu lệnh SQL sẽ trả về true nếu một trong hai vế của nó là đúng. Vì 1=1 luôn đúng, nên toàn bộ câu lệnh là đúng. Do đó, nó sẽ thông báo cho máy chủ rằng email hợp lệ và đăng nhập cho chúng ta vào tài khoản người dùng có ID 0, vốn là tài khoản quản trị viên.

Ký tự -- được sử dụng trong SQL để chú thích dữ liệu, bất kỳ hạn chế nào đối với việc đăng nhập sẽ không còn hoạt động nữa vì chúng được hiểu là chú thích.



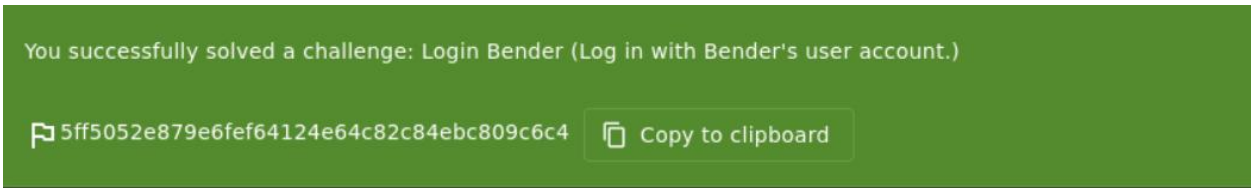
690fa3247a99d651e0b26f947baf0b79b4f404a9 ✓ Correct Answer

Question #2: Log into the Bender account!

Tương tự như ở Câu hỏi số 1, bây giờ chúng ta sẽ đăng nhập vào tài khoản của Bender! Hãy chụp lại yêu cầu đăng nhập, nhưng lần này chúng ta sẽ nhập: bender@juice-sh.op'-- vào phần email.

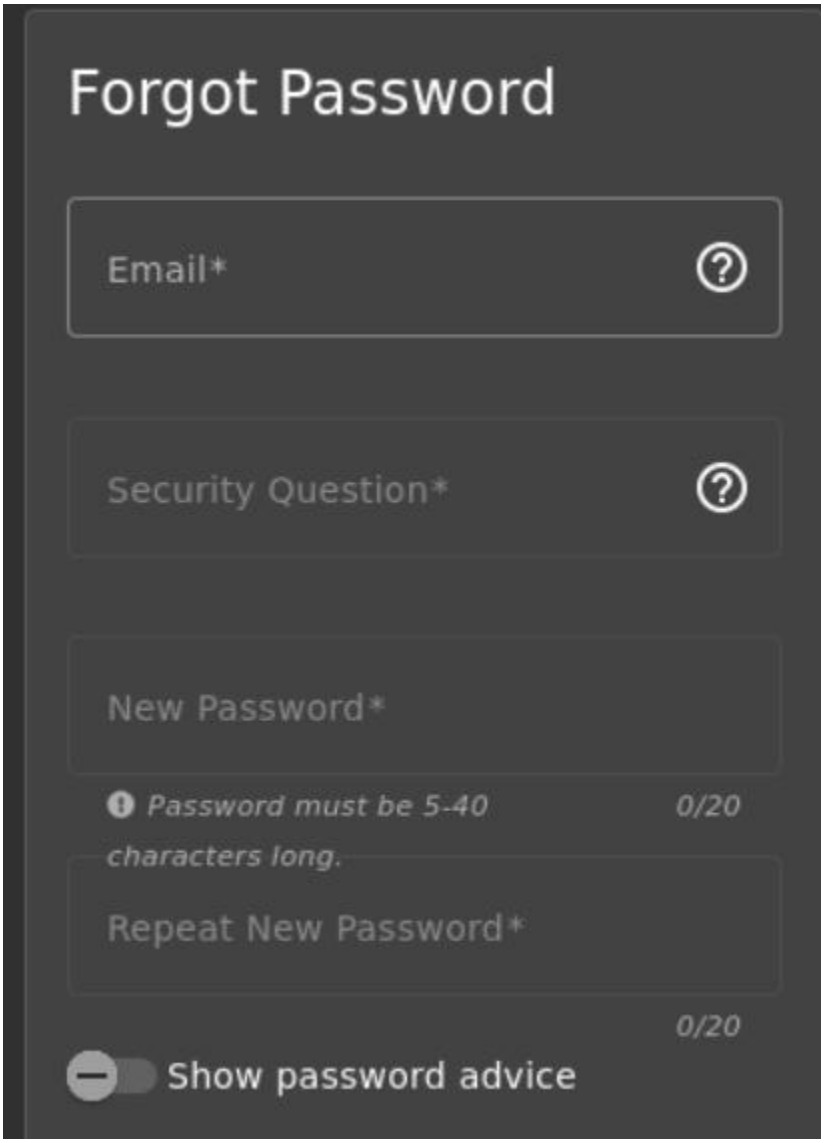
Nhưng tại sao chúng ta không dùng 1=1?

Vì địa chỉ email hợp lệ (sẽ trả về true), nên chúng ta không cần phải ép nó phải đúng. Do đó, chúng ta có thể sử dụng '--' để bỏ qua hệ thống đăng nhập. Lưu ý rằng 1=1 có thể được sử dụng khi email hoặc tên người dùng không được biết hoặc không hợp lệ.



5ff5052e879e6fef64124e64c82c84ebc809c6c4 ✓ Correct Answer

2. Who broke my lock ?



Trong nhiệm vụ này, chúng ta sẽ xem xét việc khai thác lỗ hổng xác thực thông qua các điểm yếu khác nhau. Khi nói về các lỗ hổng trong xác thực, chúng ta bao gồm các cơ chế dễ bị thao túng. Các cơ chế này, được liệt kê bên dưới, là những gì chúng ta sẽ khai thác.

- Mật khẩu yếu trong các tài khoản có quyền hạn cao
- Trang quên mật khẩu

Question #1: Bruteforce the Administrator account's password!

Chúng ta đã sử dụng tấn công SQL Injection để đăng nhập vào tài khoản Quản trị viên nhưng vẫn chưa biết mật khẩu. Hãy thử tấn công vét cạn! Chúng ta sẽ lại bắt giữ yêu cầu đăng nhập, nhưng thay vì gửi qua máy chủ proxy, chúng ta sẽ gửi trực tiếp đến Intruder.

Vào mục Positions, sau đó chọn nút Clear §. Trong trường mật khẩu, hãy đặt hai ký tự § bên trong dấu ngoặc kép.

```
POST /rest/user/login HTTP/1.1
Host: 10.48.140.47
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:147.0) Gecko/20100101 Firefox/147.0
Accept: application/json, text/plain, */*
Accept-Language: en-GB,en;q=0.9
Accept-Encoding: gzip, deflate, br
Content-Type: application/json
Content-Length: 44
Origin: http://10.48.140.47
Connection: keep-alive
Referer: http://10.48.140.47/
Cookie: language=en; continueCode=1OzBZxNpnLrM5WmgEKv8XakQ7DA6gJuVbdJ6yOlV9Pow1jYqbz2eRB34oE5m
Priority: u=0

{"email":"admin@juice-sh.op","password":"§§"}
```

Đối với payload, chúng ta sẽ sử dụng tập tin best1050.txt từ Seclists. (Có thể cài đặt bằng lệnh: apt-get install seclists)

Sau khi tải tập tin vào Burp, hãy bắt đầu cuộc tấn công. Chúng ta sẽ cần lọc yêu cầu theo trạng thái.

Yêu cầu không thành công sẽ nhận được mã lỗi 401 Unauthorized.

Status ▼
401

Trong khi đó, một yêu cầu thành công sẽ trả về mã trạng thái 200 OK.

Status ▲
200

3. Intruder attack of http://10.48.140.47

Results | Positions

Intruder attack results filter: Showing all items

Request	Payload	Status code	Response received	Error	Timeout	Length	Commen
117	admin123	200	11			1200	
132	amateur	401	7			413	
131	amanda1	401	7			413	
130	amanda	401	7			413	
129	alpha	401	7			413	
128	alexis	401	7			413	
127	alex	401	7			413	
126	alejandro	401	7			413	
125	alejandra	401	7			413	
124	alberto	401	12			413	
123	albert	401	7			413	

Mật khẩu: admin123

You successfully solved a challenge: Password Strength (Log in with the administrator's user credentials without previously changing them or applying SQL Injection.) X

ff4aebffe31b0ffdea9bdd0207a16a3c01ac6c56 Copy to clipboard

ff4aebffe31b0ffdea9bdd0207a16a3c01ac6c56 ✓ Correct Answer

Question #2: Reset Jim's password!

Dù bạn có tin hay không, cơ chế đặt lại mật khẩu cũng có thể bị lợi dụng! Khi nhập vào trường email trên trang Quên mật khẩu, câu hỏi bảo mật của Jim được đặt là "Tên đệm của anh/chị/em ruột lớn nhất của bạn?".

Trong Nhiệm vụ 2, chúng ta phát hiện ra rằng Jim có thể có liên quan đến Star Trek. Tìm kiếm "Jim Star Trek" trên Google cho chúng ta một trang wiki về James T. Kirk từ Star Trek.

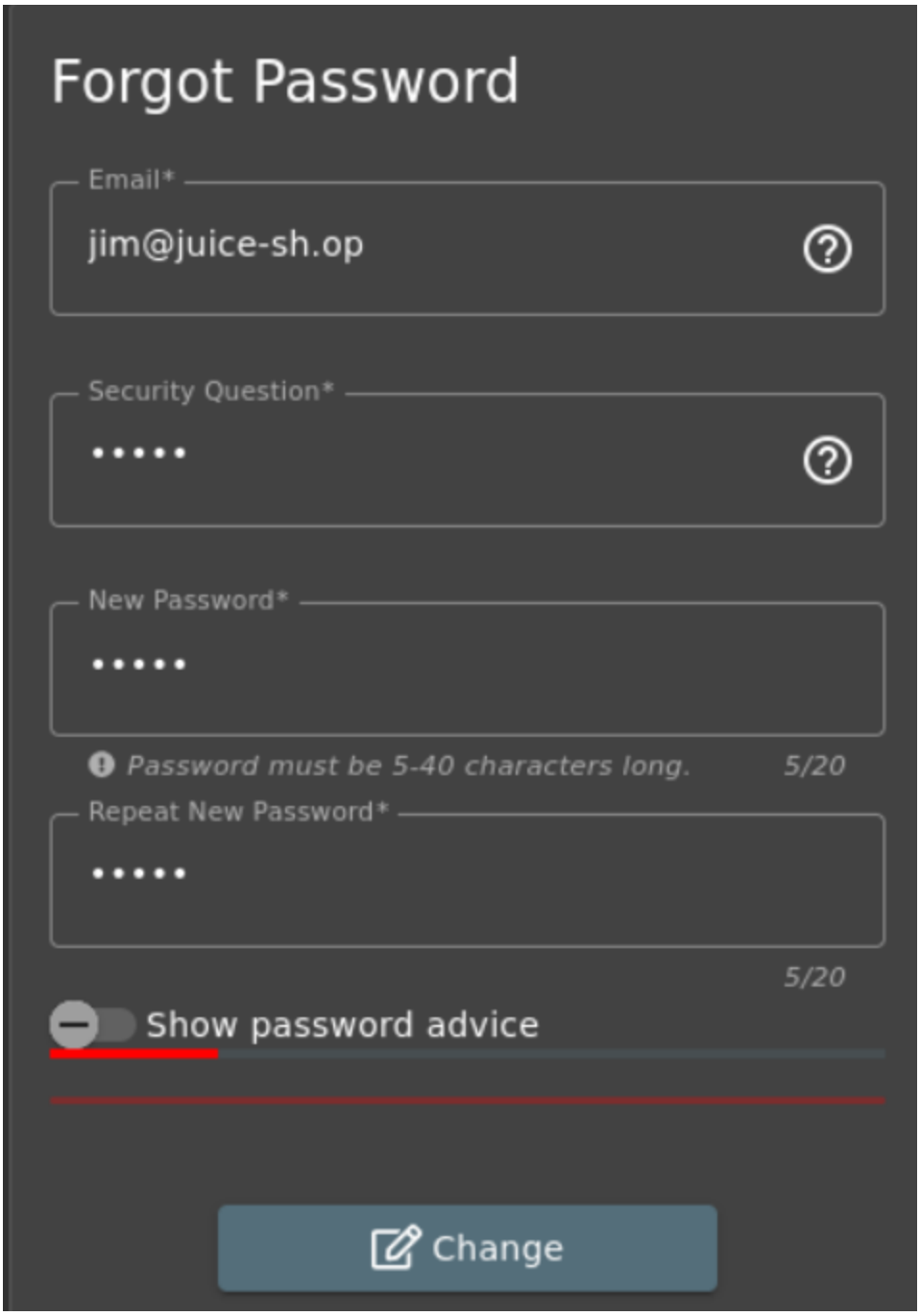
Khi xem trang wiki, chúng ta thấy rằng anh ấy có một người anh trai.

Family	George Samuel Kirk Sr. (father) Winona Kirk (mother) George Samuel Kirk Jr. (brother) Tiberius Kirk (grandfather) James (maternal grandfather) Aurelan Kirk (sister-in-law) Peter Kirk (nephew) 2 other nephews
Children	David Marcus
Origin	Riverside, Iowa, United States

Hình như tên đệm của anh trai anh ấy là Samuel.

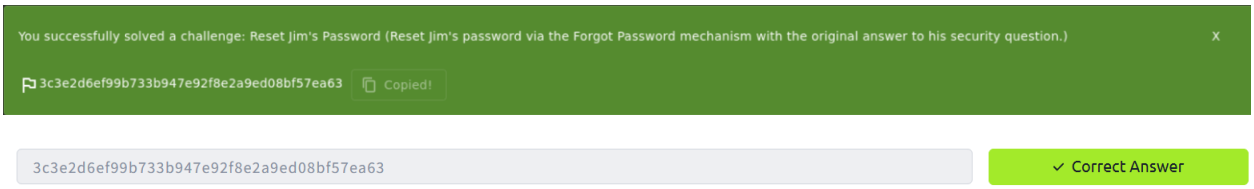
Nhập thông tin đó vào trang Quên mật khẩu cho phép bạn thay đổi mật khẩu của anh ấy thành công.

Bạn có thể thay đổi nó thành bất cứ thứ gì bạn muốn!

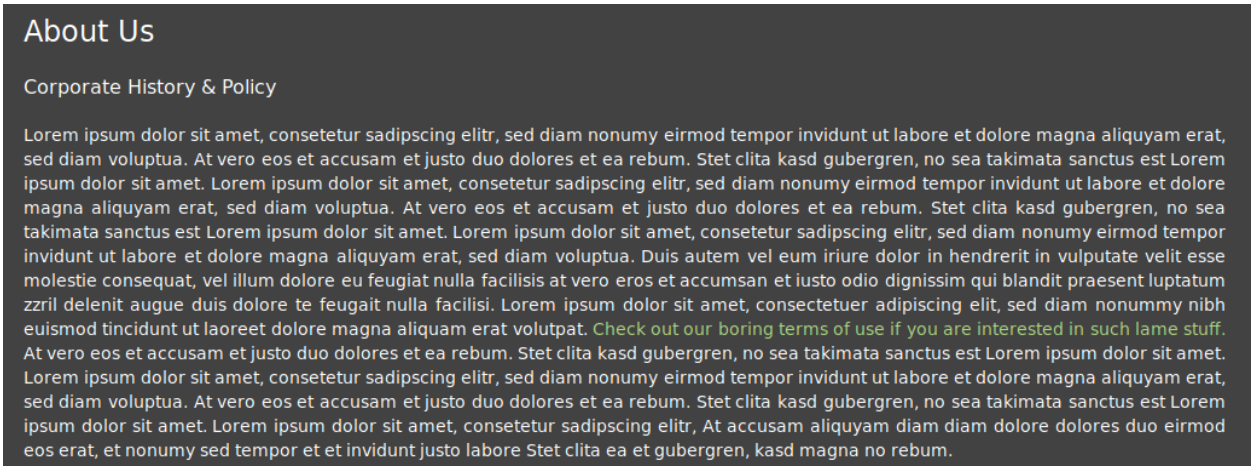


Sau khi reset mật khẩu, ta đăng nhập lại.

Kết quả



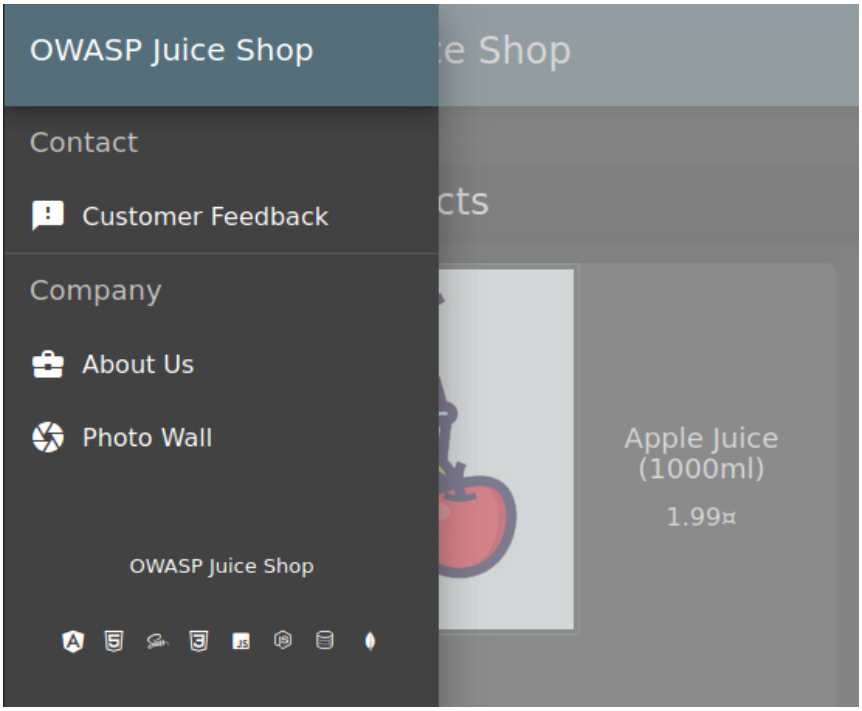
3. AH! Don’t look !



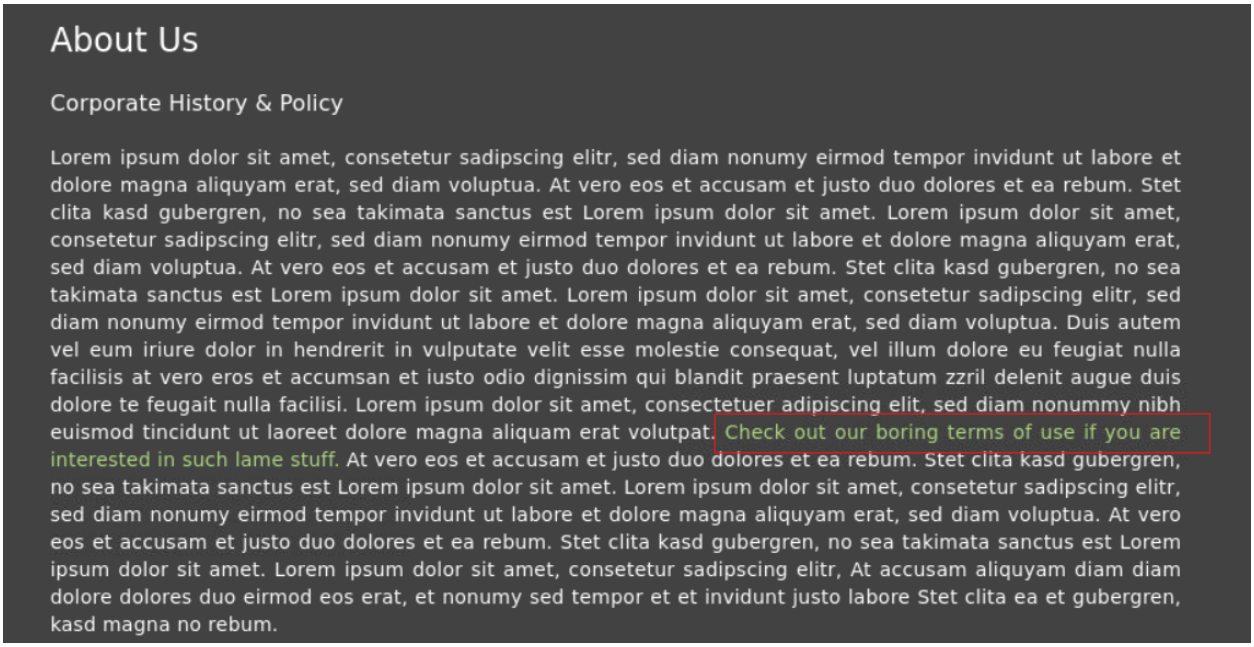
Một ứng dụng web cần lưu trữ và truyền tải dữ liệu nhạy cảm một cách an toàn và bảo mật. Tuy nhiên, trong một số trường hợp, nhà phát triển có thể không bảo vệ dữ liệu nhạy cảm đúng cách, khiến nó dễ bị tấn công.

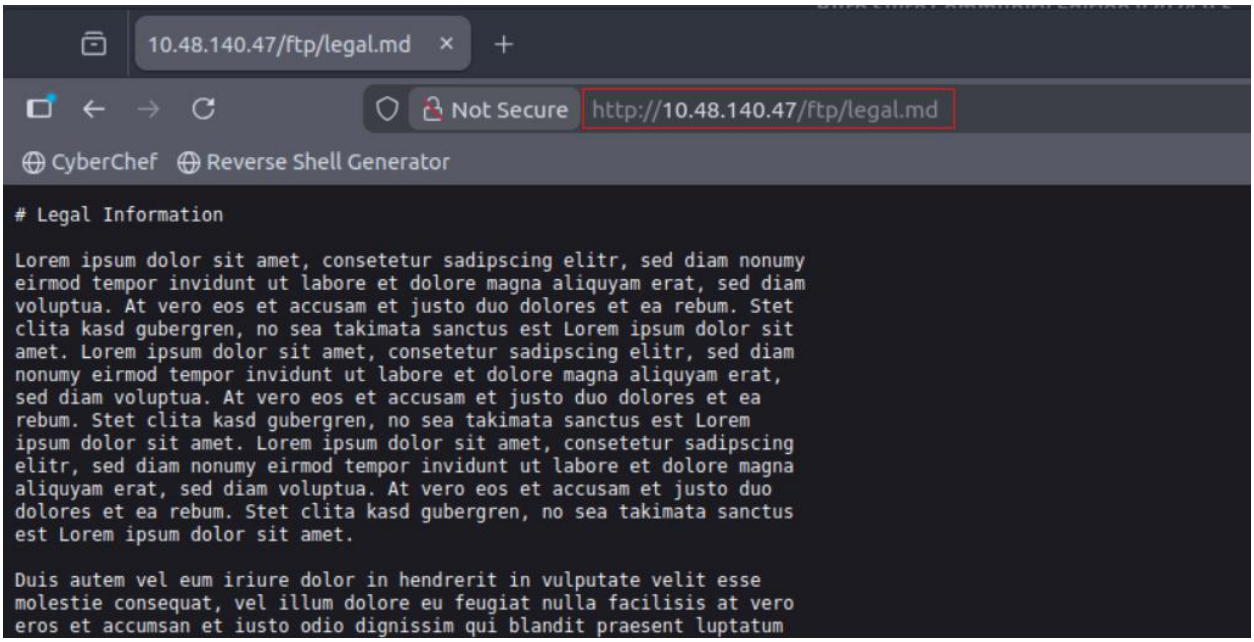
Hầu hết thời gian, việc bảo vệ dữ liệu không được áp dụng nhất quán trên toàn bộ ứng dụng web, khiến một số trang có thể truy cập được bởi công chúng. Đôi khi, thông tin bị rò rỉ ra công chúng mà nhà phát triển không hề hay biết, khiến ứng dụng web dễ bị tấn công.

Question #1: Access the Confidential Document!

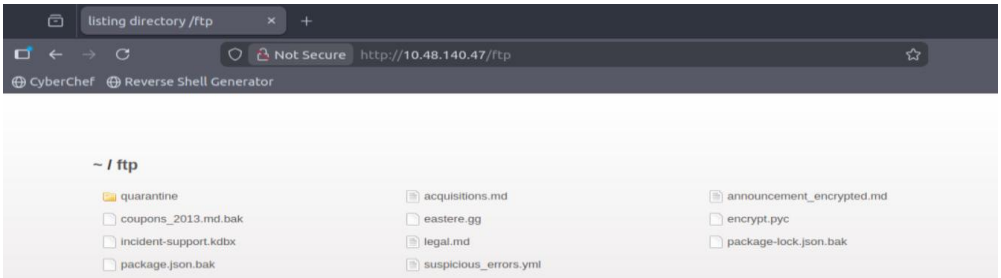


Truy cập trang Giới thiệu về chúng tôi, rồi di chuột qua "Xem điều khoản sử dụng của chúng tôi".





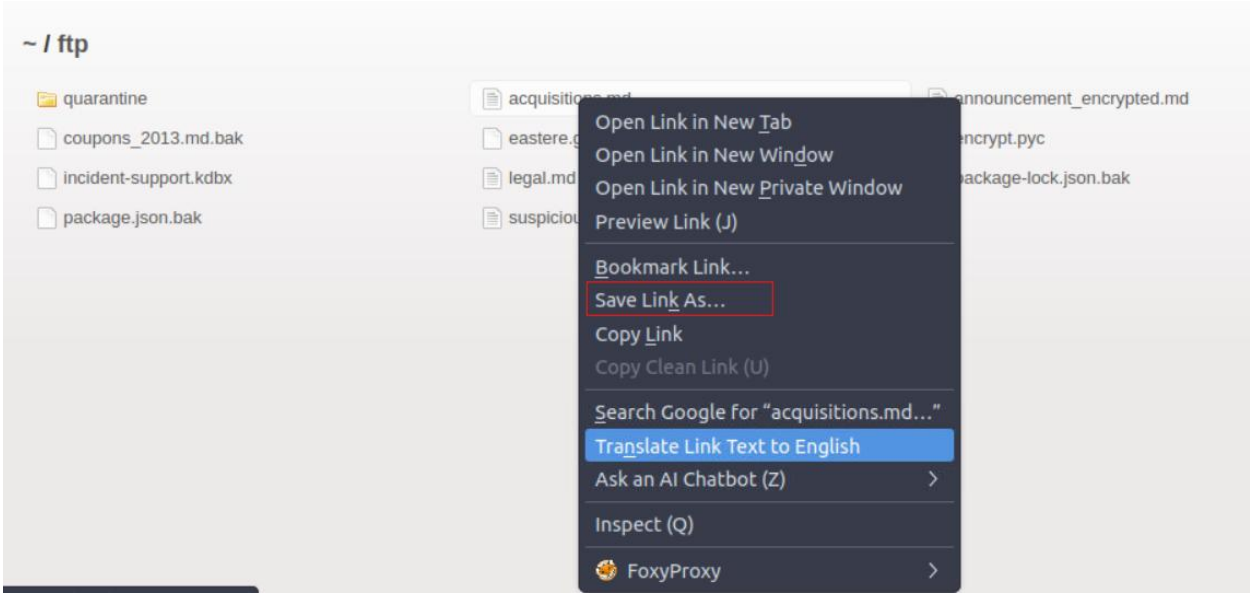
Ta thử xóa chỉ để lại path /ftp.

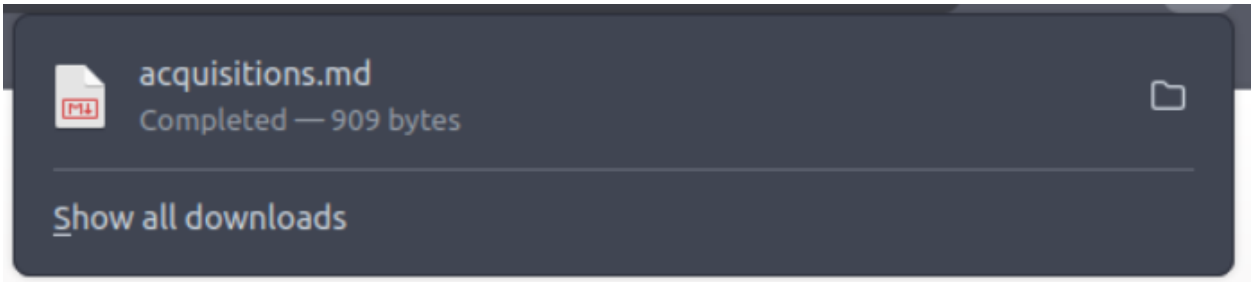


Khi truy cập vào thư mục /ftp/, bạn sẽ thấy rằng nó được công khai!

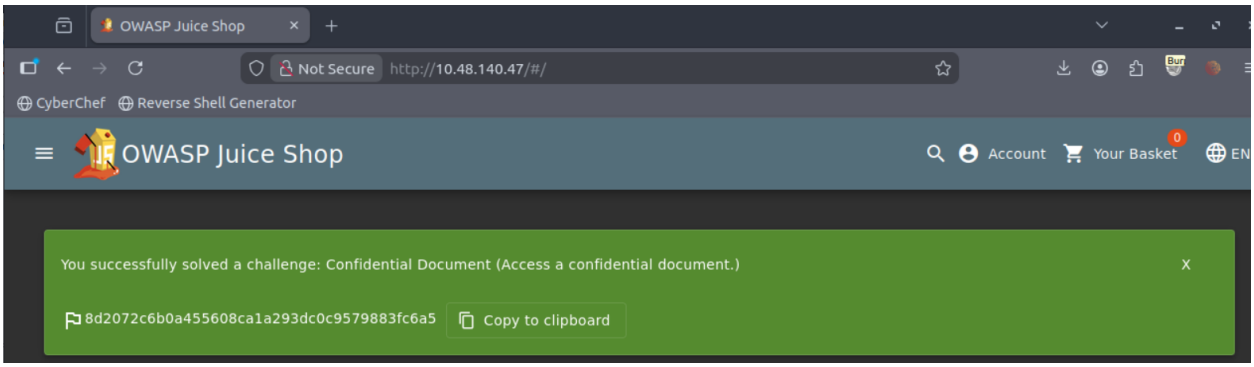
Chúng ta sẽ tải xuống tập tin acquisitions.md và lưu lại. Có vẻ như còn có một số tập tin khác đáng quan tâm ở đây nữa.

Sau khi tải xuống, hãy truy cập trang chủ để nhận cờ!





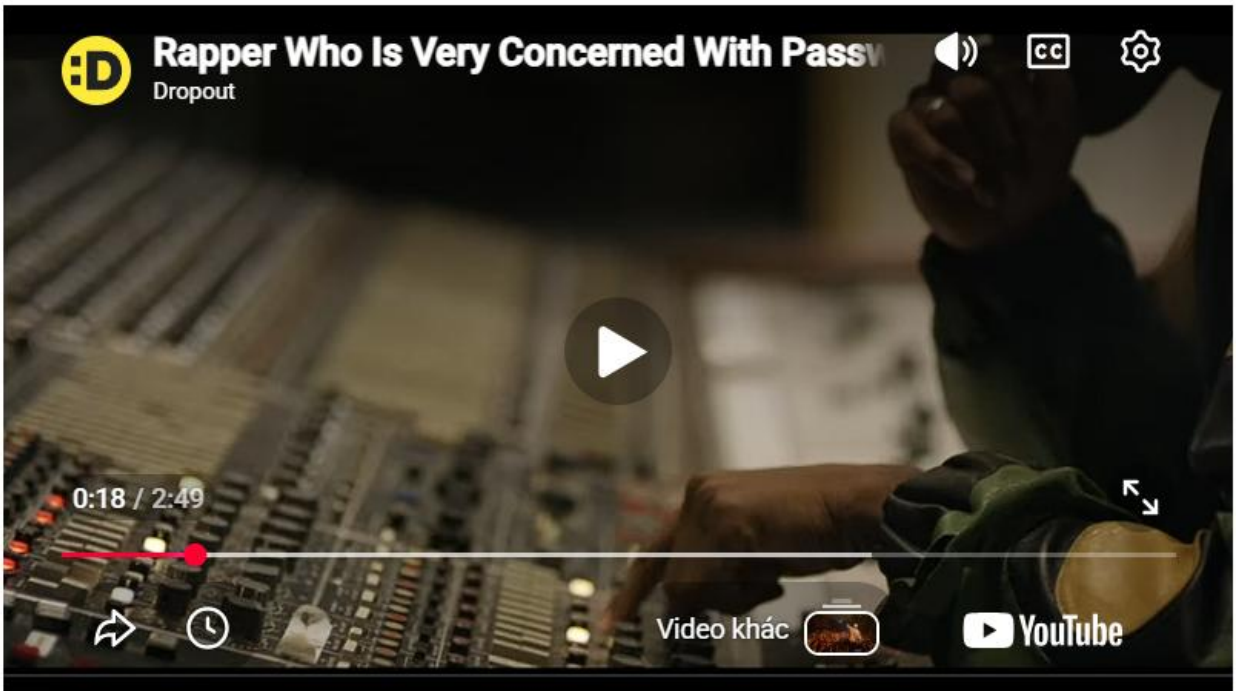
Ta refresh lại trang



8d2072c6b0a455608ca1a293dc0c9579883fc6a5 ✓ Correct Answer

Question #2: Log into MC SafeSearch's account!

Ta xem đoạn video do THM cung cấp

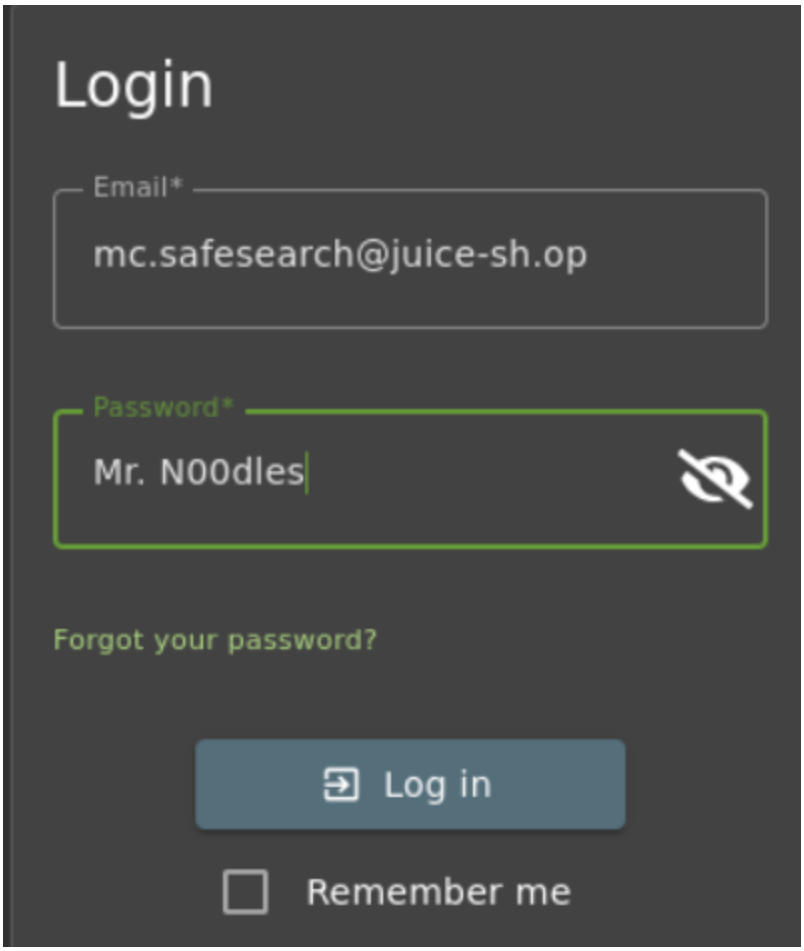


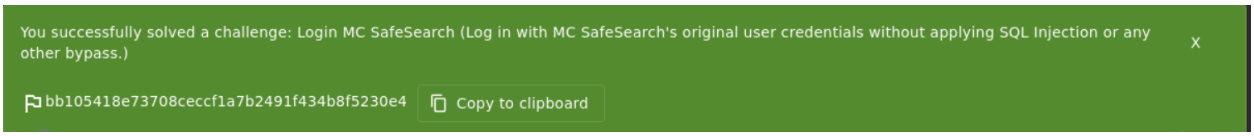
[Rapper Who Is Very Concerned With Password Security]

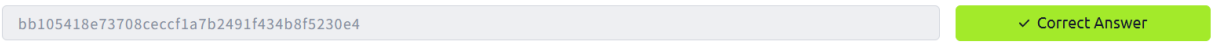
Sau khi xem video, có một số đoạn trong bài hát khá nổi bật.

Anh ấy nói rằng mật khẩu của mình là "Mr. Noodles" nhưng anh ấy đã thay thế một số "nguyên âm thành số không", nghĩa là anh ấy chỉ thay thế các chữ "o" bằng số 0.

Giờ thì chúng ta đã biết mật khẩu của tài khoản mc.safesearch@juice-sh.op là "Mr. N00dles".







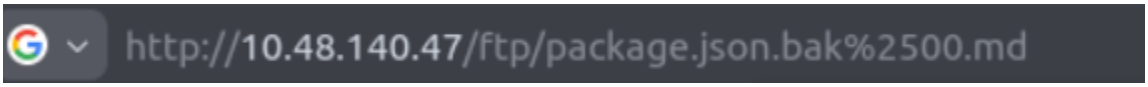
Question #3: Download the Backup file!

Bây giờ chúng ta sẽ quay lại thư mục http://10.48.140.47 (mở trong tab mới) /ftp/ và thử tải xuống package.json.bak. Nhưng có vẻ như chúng ta gặp lỗi 403, cho biết chỉ có thể tải xuống các tệp .md và .pdf.

Để khắc phục điều này, chúng ta sẽ sử dụng một thủ thuật vượt qua bằng ký tự gọi là "Poison Null Byte". Một Poison Null Byte trông như thế này: %00.

Lưu ý: vì chúng ta có thể tải xuống bằng URL, nên chúng ta cần mã hóa nó thành định dạng mã hóa URL.

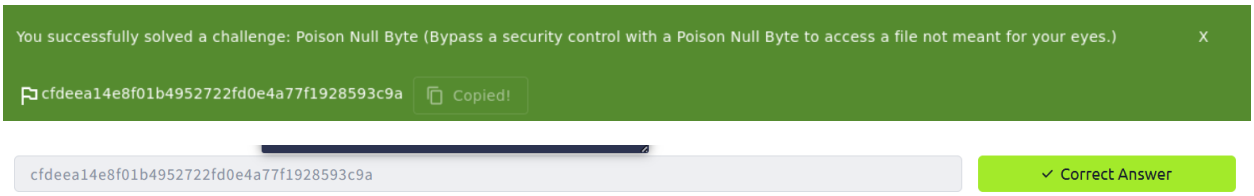
Poison Null Byte bây giờ sẽ trông như thế này: %2500. Thêm ký tự này và sau đó là .md vào cuối sẽ giúp vượt qua lỗi 403!



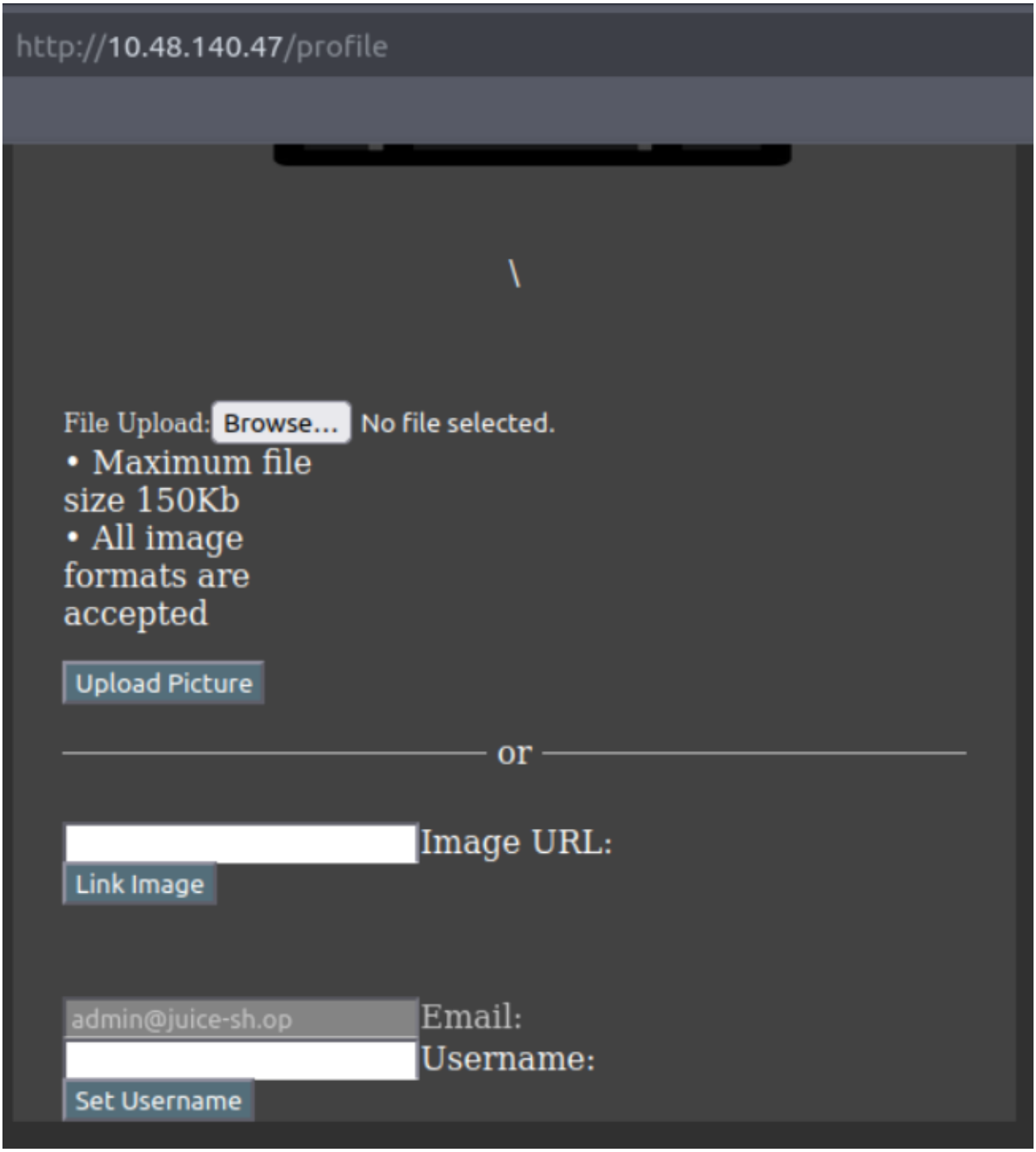
Kết quả

Poison Null Byte thực chất là một ký tự kết thúc NULL. Bằng cách đặt một ký tự NULL vào chuỗi tại một vị trí nhất định, chuỗi sẽ báo cho máy chủ biết rằng cần kết thúc tại điểm đó, làm cho phần còn lại của chuỗi trở nên null.

Refresh lại page, ta nhận được flag.



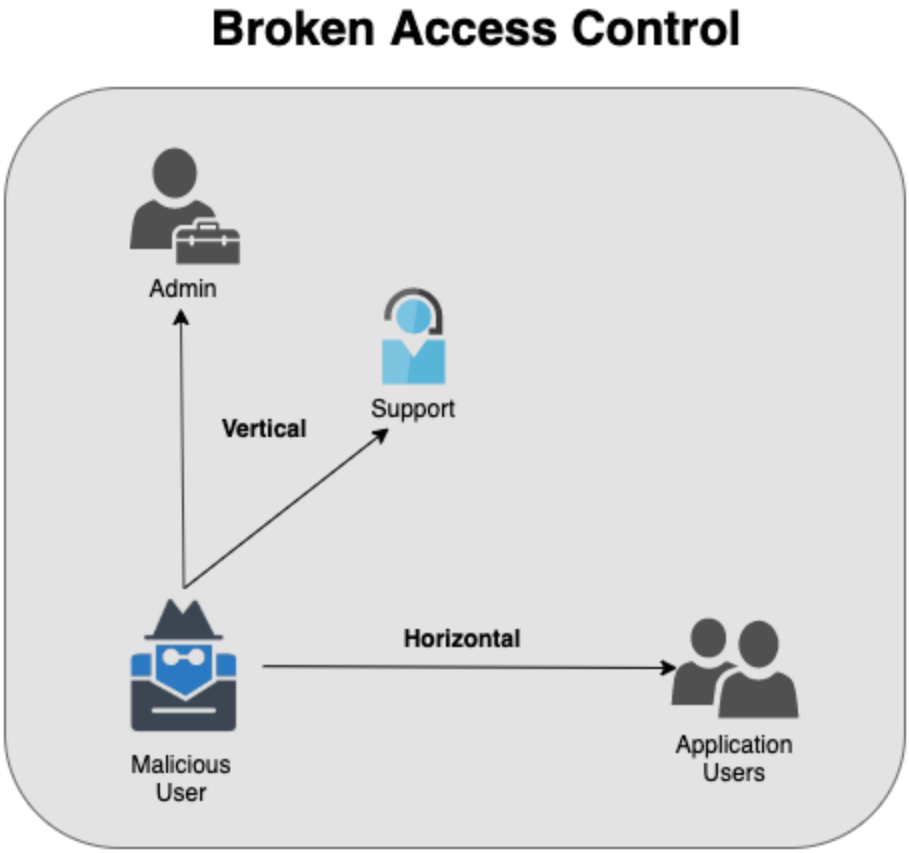
4. Who’s flying this thing ?



Các hệ thống hiện đại cho phép nhiều người dùng truy cập vào các trang khác nhau. Quản trị viên thường sử dụng trang quản trị để chỉnh sửa, thêm và xóa các thành phần khác nhau của một trang web. Bạn có thể sử dụng các trang này khi xây dựng trang web bằng các chương trình như Weebly hoặc Wix.

Khi phát hiện các lỗ hổng hoặc lỗi liên quan đến kiểm soát truy cập, chúng sẽ được phân loại vào một trong hai loại sau:

Horizontal Privilege Escalation	Xảy ra khi người dùng có thể thực hiện hành động hoặc truy cập dữ liệu của người dùng khác có cùng cấp độ quyền hạn.
Vertical Privilege Escalation	Xảy ra khi người dùng có thể thực hiện hành động hoặc truy cập dữ liệu của người dùng khác có quyền hạn cao hơn.

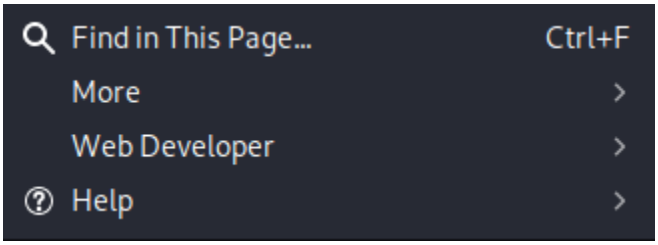


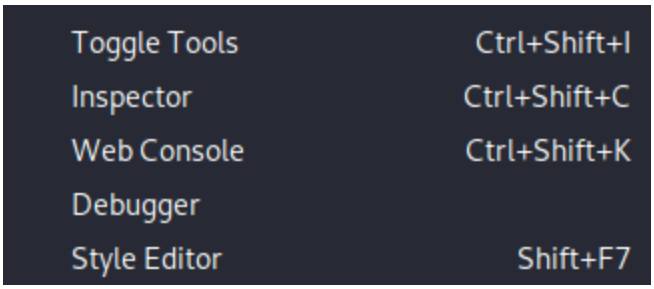
Question #1: Access the administration page!

Đầu tiên, chúng ta sẽ mở Trình gỡ lỗi trên Firefox.

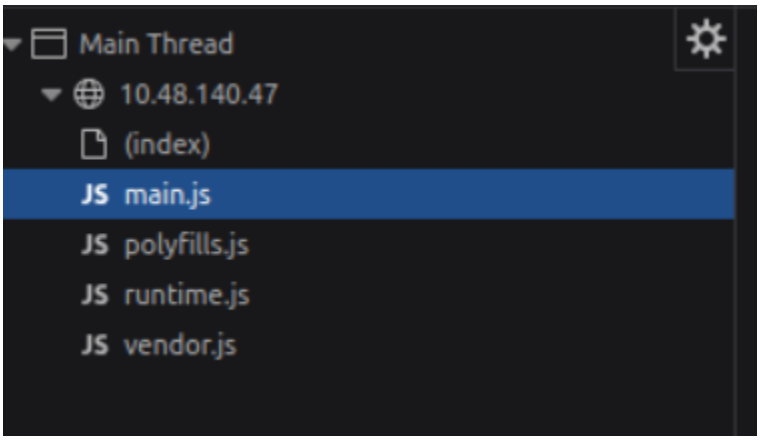
(Hoặc Mã nguồn trên Chrome.)

Bạn có thể thực hiện điều này bằng cách điều hướng đến đó trong menu Nhà phát triển web.





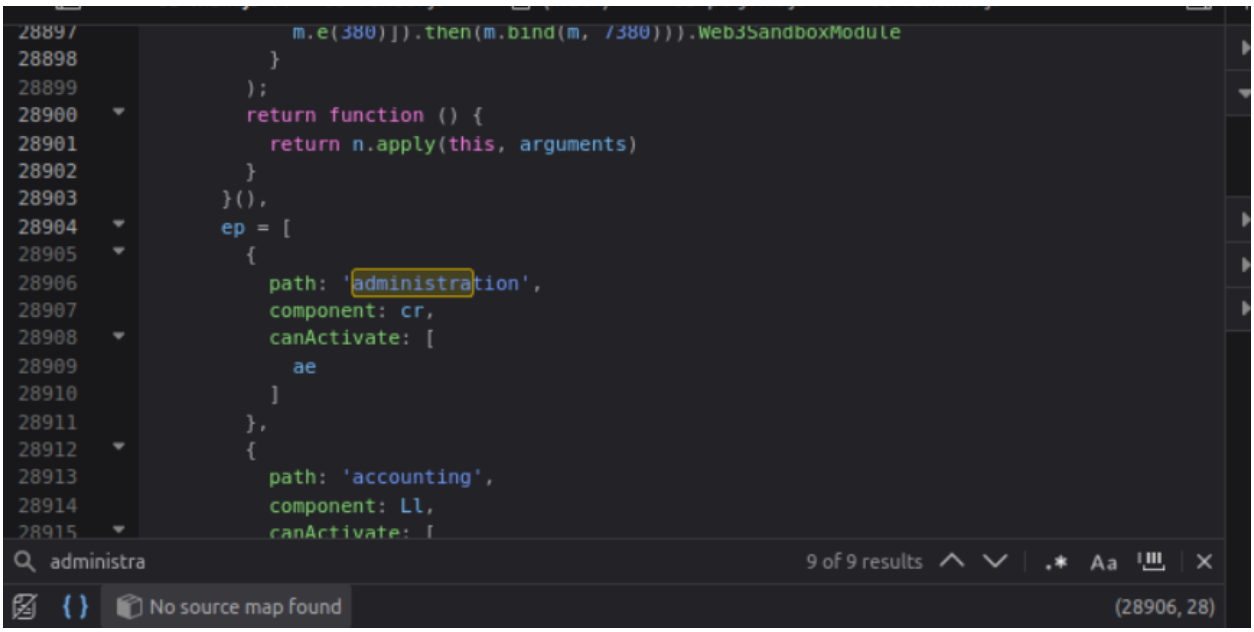
Tiếp theo, chúng ta sẽ làm mới trang và tìm tệp JavaScript có tên main.js



Để chuyển sang định dạng dễ đọc hơn, hãy nhấp vào nút { } ở phía dưới.

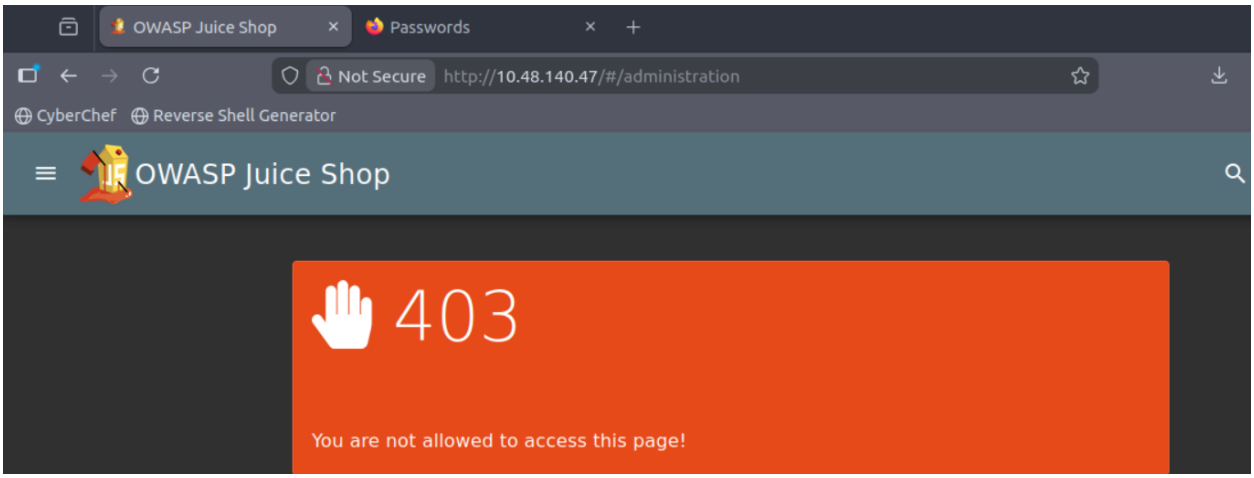
Bây giờ hãy tìm kiếm cụm từ "admin".

Bạn sẽ thấy một vài từ khác nhau chứa "admin", nhưng từ chúng ta đang tìm kiếm là "path: administration".

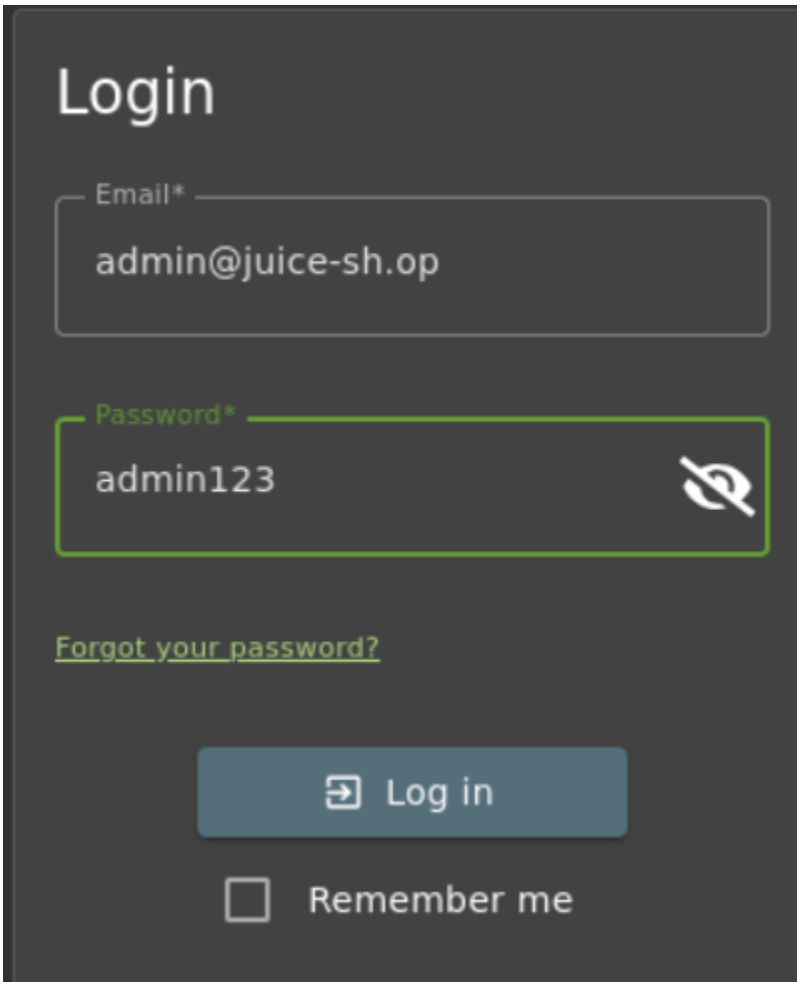


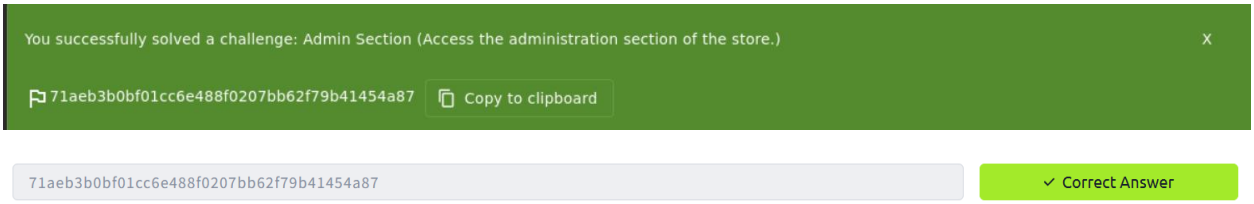
Điều này gợi ý đến một trang có tên là "/#/administration" như có thể thấy ở đường dẫn "about" vài dòng bên dưới, nhưng truy cập vào đó khi chưa đăng nhập thì không hoạt động.

Vì đây là trang quản trị, nên việc cần phải đăng nhập bằng tài khoản quản trị viên để xem được là điều dễ hiểu.



Ta đăng nhập bằng tài khoản quản trị viên lúc trước để nhận flag.

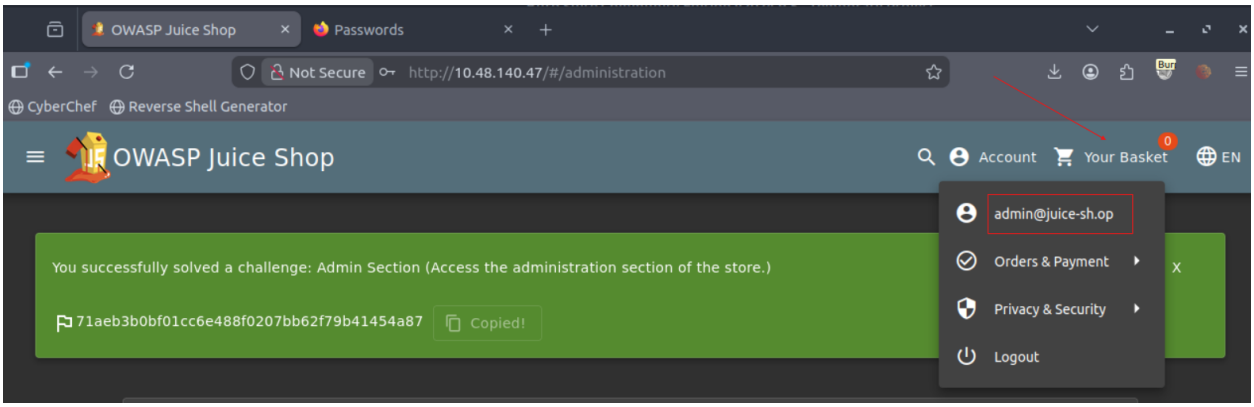




Question #2: View another user's shopping basket!

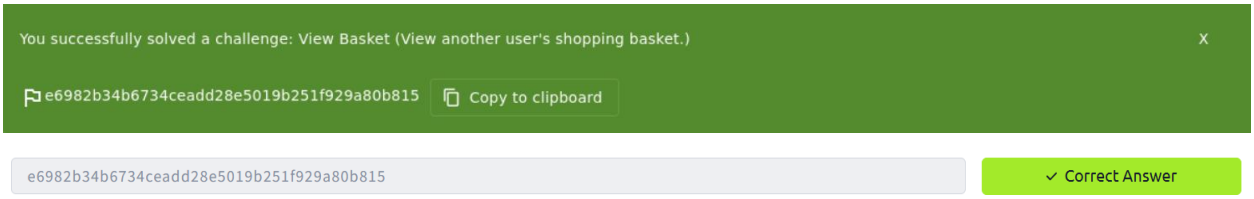
Đăng nhập vào tài khoản Quản trị viên và nhấp vào 'Your Basket'. Hãy đảm bảo Burp đang chạy để bạn có thể bắt được yêu cầu!

Chuyển tiếp từng yêu cầu cho đến khi bạn thấy: GET /rest/basket/1 HTTP/1.1



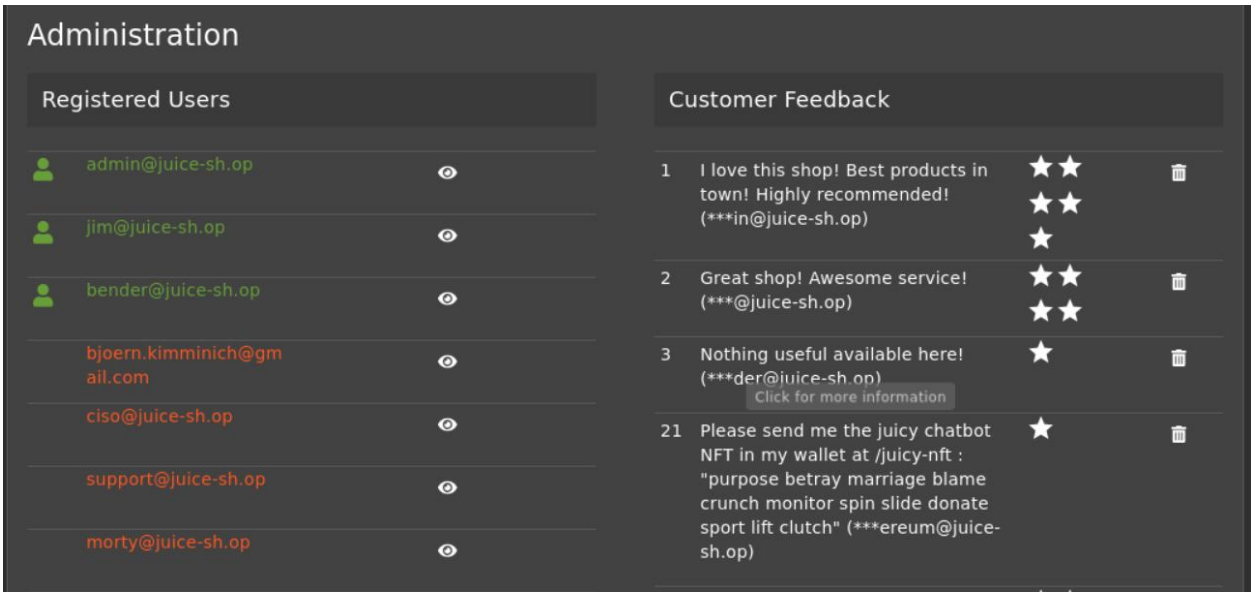
Bây giờ, chúng ta sẽ đổi số 1 sau /basket/ thành số 2.

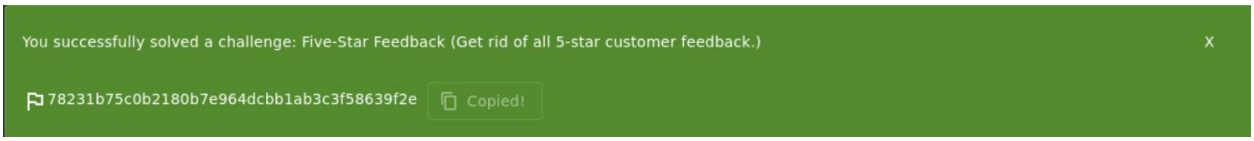
Giờ thì nó sẽ hiển thị giỏ hàng của Người dùng có ID 2. Bạn cũng có thể làm điều này với các Người dùng có ID khác, miễn là họ có giỏ hàng!



Question #3: Remove all 5-star reviews!

Truy cập lại trang (mở trong tab mới)http://10.48.140.47/#/administration và nhấp vào biểu tượng thùng rác bên cạnh đánh giá 5 sao!

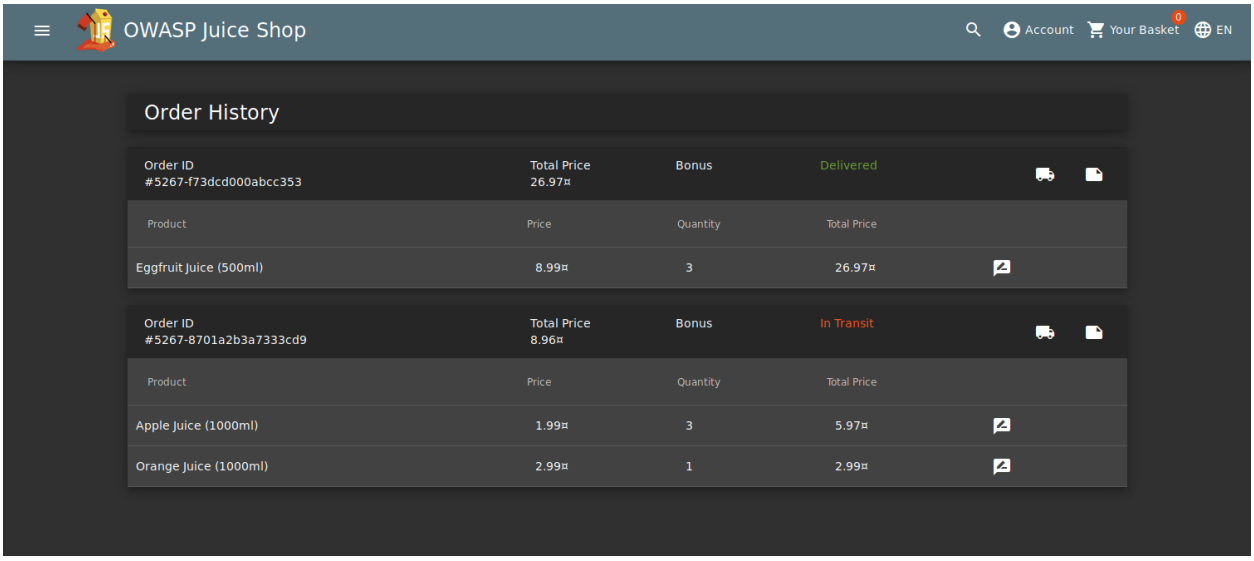




78231b75c0b2180b7e964dcbb1ab3c3f58639f2e

✓ Correct Answer

5. Where did that come from ?



XSS or Cross-site scripting, là một lỗ hổng cho phép kẻ tấn công chạy mã JavaScript trong các ứng dụng web. Đây là một trong những lỗi thường gặp nhất trong các ứng dụng web. Độ phức tạp của chúng dao động từ dễ đến cực khó, vì mỗi ứng dụng web phân tích các truy vấn theo cách khác nhau.

Có ba loại tấn công XSS chính:

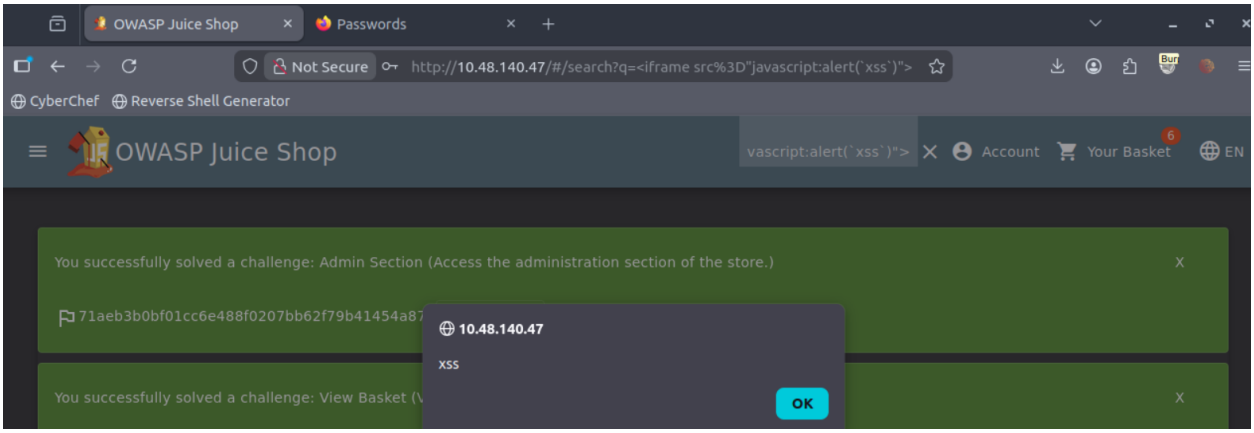
DOM (Special)	Lỗ hổng DOM XSS (Document Object Model-based Cross-site Scripting) sử dụng môi trường HTML để thực thi mã JavaScript độc hại. Loại tấn công này thường sử dụng thẻ HTML <script></script>.
Persistent (Server-side)	Lỗ hổng XSS Persistent là mã JavaScript được thực thi khi máy chủ tải trang chứa nó. Điều này có thể xảy ra khi máy chủ không xử lý an toàn dữ liệu người dùng khi tải lên trang. Chúng thường được tìm thấy trên các bài đăng blog.
Reflected (Client-side)	Lỗ hổng XSS Reflected là mã JavaScript được thực thi ở phía máy khách của ứng dụng web. Loại lỗ hổng này thường gặp nhất khi máy chủ không lọc dữ liệu tìm kiếm.

Question #1: Perform a DOM XSS!

Chúng ta sẽ sử dụng phần tử iframe với thẻ cảnh báo JavaScript:

<iframe src="javascript:alert(`xss`)">

Nhập đoạn mã này vào thanh tìm kiếm sẽ kích hoạt cảnh báo.

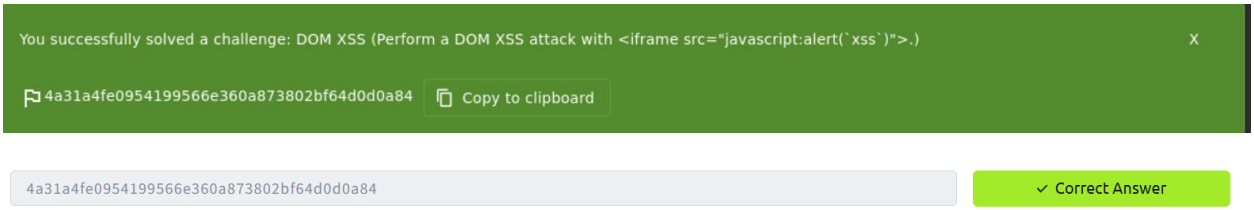


Lưu ý rằng chúng ta đang sử dụng iframe, một phần tử HTML phổ biến được tìm thấy trong nhiều ứng dụng web, có những phần tử khác cũng tạo ra kết quả tương tự.

Loại tấn công XSS này, còn được gọi là XFS (Cross-Frame Scripting), là một trong những hình thức phổ biến nhất để phát hiện XSS trong các ứng dụng web.

Các trang web cho phép người dùng sửa đổi iframe hoặc các phần tử DOM khác rất có thể dễ bị tấn công XSS.

Ta nhận được flag.

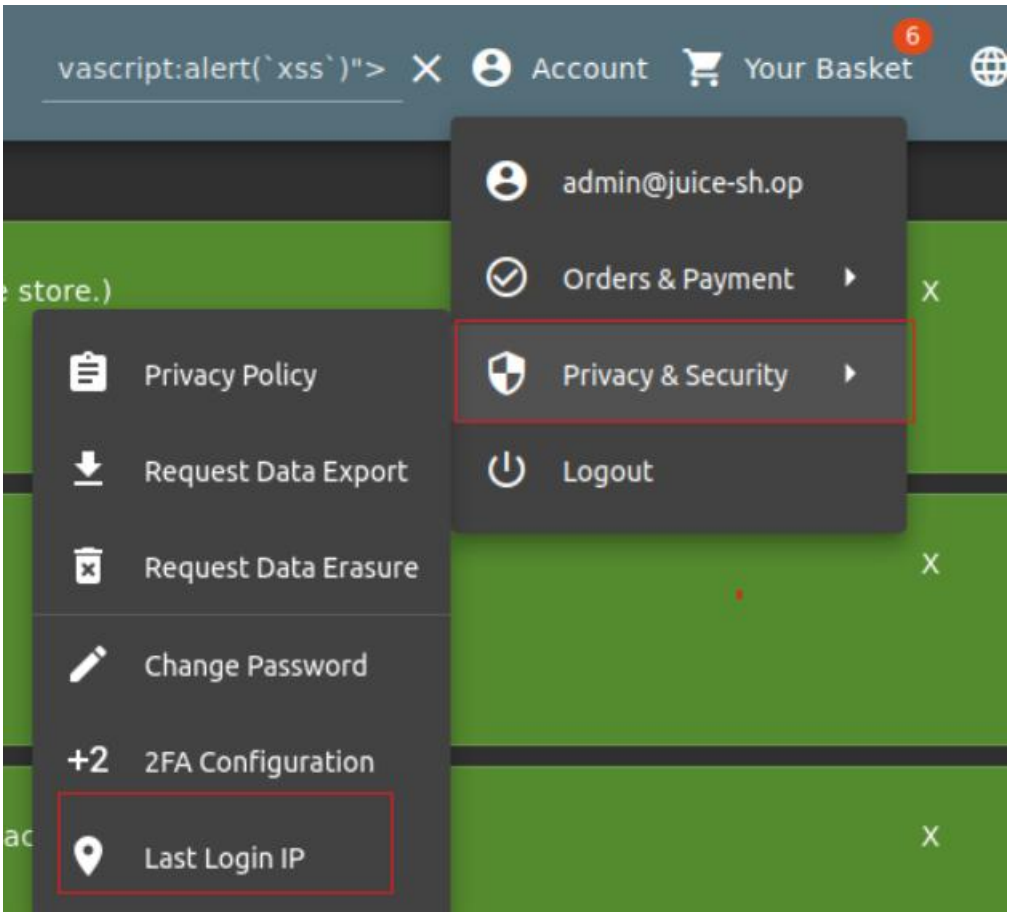


Thông thường, thanh tìm kiếm sẽ gửi yêu cầu đến máy chủ và nhận lại thông tin liên quan, nhưng đây chính là điểm yếu. Nếu không có quy trình lọc dữ liệu đầu vào đúng cách, chúng ta có thể thực hiện tấn công XSS vào thanh tìm kiếm.

Question #2: Perform a persistent XSS!

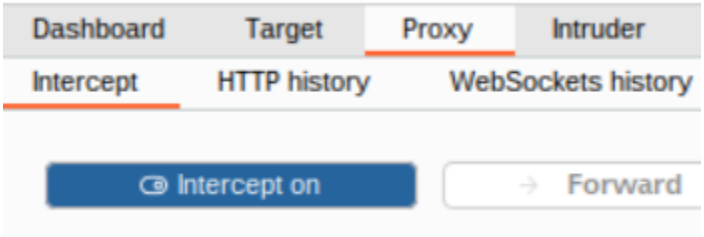
Đầu tiên, hãy đăng nhập vào tài khoản quản trị.

Chúng ta sẽ điều hướng đến trang "Last login IP" cho cuộc tấn công này.



Nó sẽ hiển thị địa chỉ IP cuối cùng là 0.0.0.0 hoặc 10.x.x.x

Vì nó ghi lại địa chỉ IP đăng nhập 'lần cuối', chúng ta sẽ đăng xuất để nó ghi lại địa chỉ IP 'mới'.

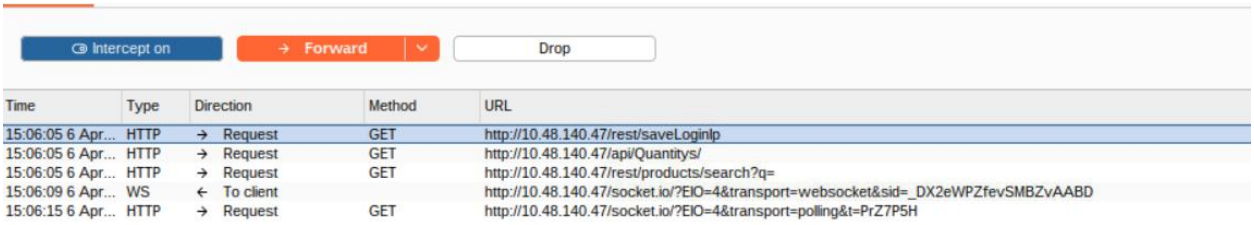


Hãy đảm bảo rằng Burp intercept đã được bật để nó có thể bắt được yêu cầu đăng xuất.

Tiếp theo, chúng ta sẽ chuyển sang tab Headers và thêm một header mới:

<iframe src="javascript:alert(`xss`)">

Ấn Foward



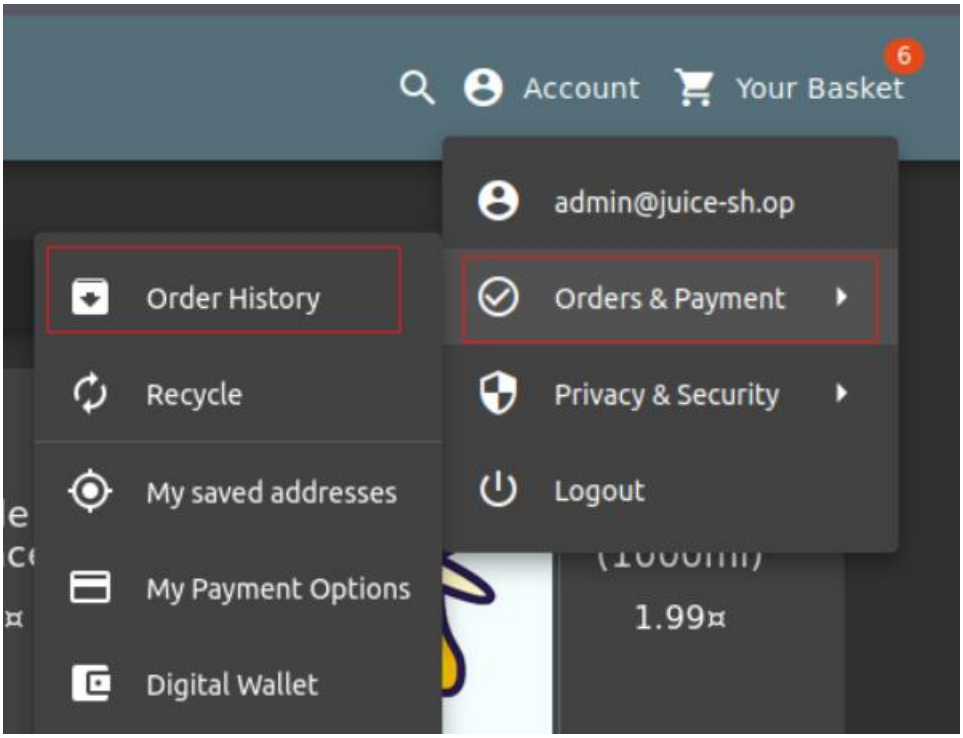
Kết quả

Tiêu đề True-Client-IP tương tự như tiêu đề X-Forwarded-For, cả hai đều cho máy chủ hoặc máy chủ proxy biết địa chỉ IP của máy khách. Do không có bước lọc thông tin trong tiêu đề này, chúng ta có thể thực hiện tấn công XSS.

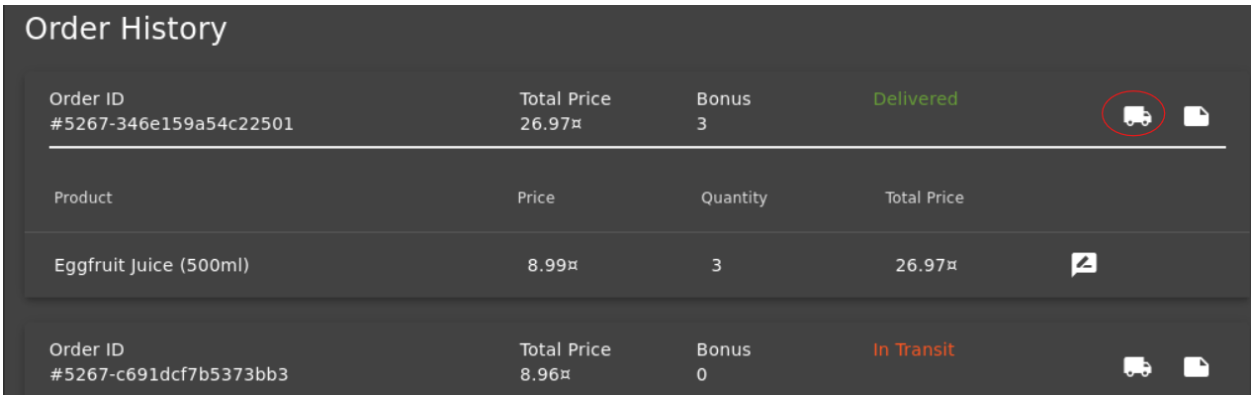
Question #3: Perform a reflected XSS!

Đầu tiên, chúng ta cần phải truy cập đúng trang để thực hiện tấn công XSS Reflected.

Đăng nhập vào tài khoản quản trị và điều hướng đến trang 'Order History'.

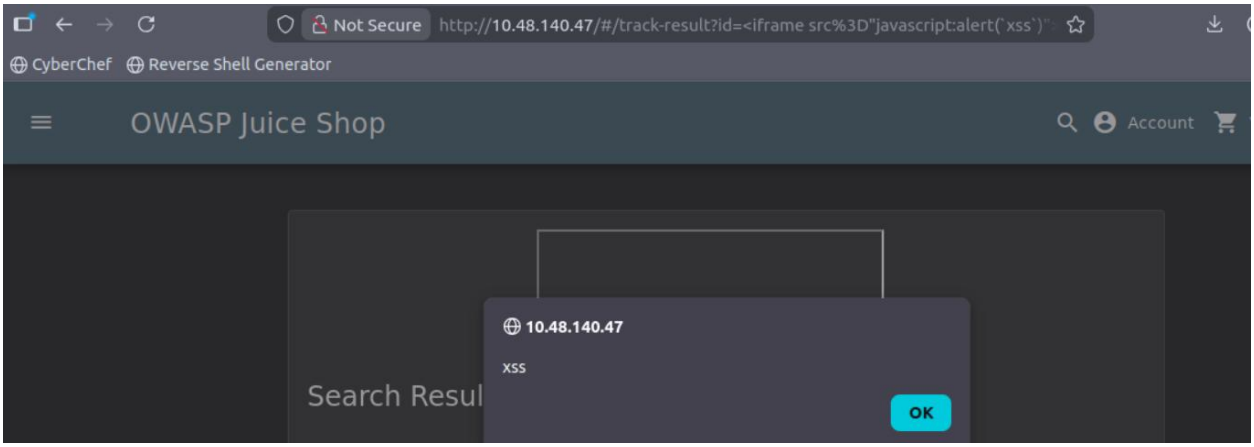


Từ đó bạn sẽ thấy biểu tượng "Xe tải", nhấp vào đó sẽ đưa bạn đến trang kết quả theo dõi. Bạn cũng sẽ thấy có một ID được ghép nối với đơn hàng.



Chúng ta sẽ sử dụng lỗ hổng XSS iframe, <iframe src="javascript:alert(`xss`)">, thay thế cho 5267-f73dcd000abcc353

Sau khi gửi URL, hãy làm mới trang và bạn sẽ nhận được cảnh báo XSS!



305021787d3e9cd9cebc057a021c2504550bb3b6

✓ Correct Answer